Il linguaggio del rischio — Explanation

Ruolo: Penetration Tester — tier **va** (Vulnerability Analyst, CREST CPSA)
Lab id: risk-language · **Difficoltà**: Base · **Durata stimata**: ~1.5h-2h
Lab component: lxr:net-perimeter (condiviso con "Primo contatto" e "Come da manuale")

---

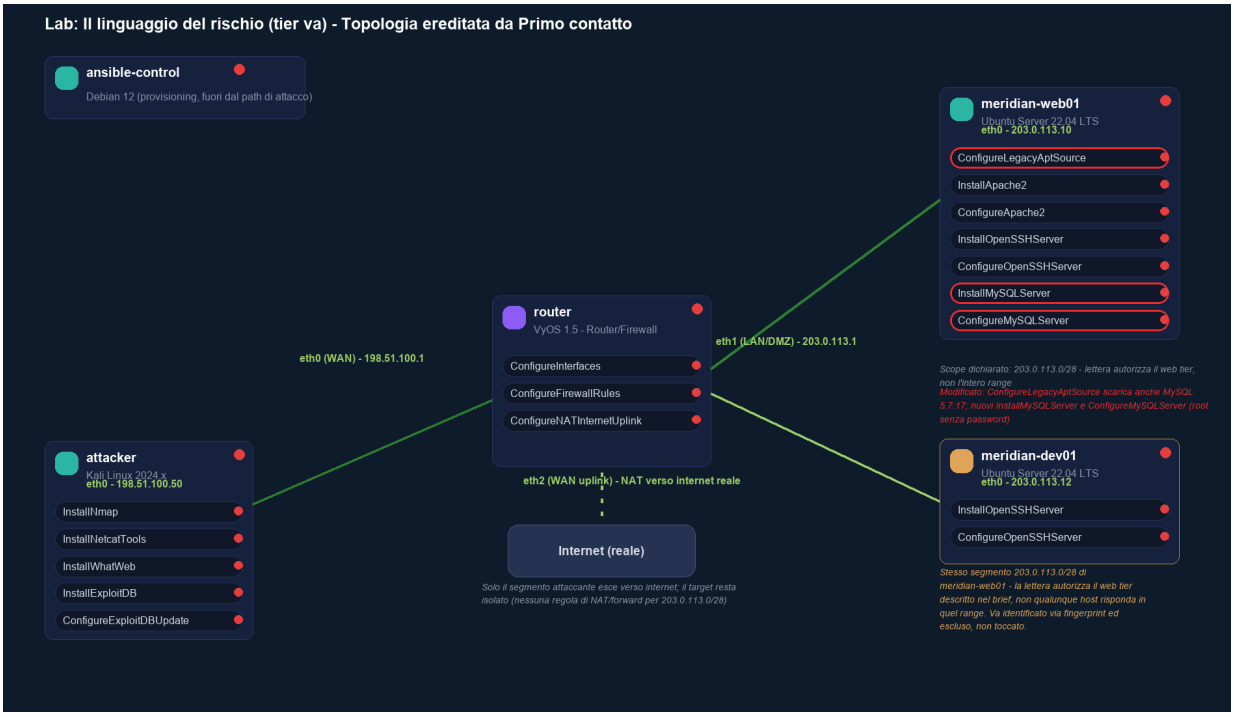
1. Schermata del lab (Avvia lab)



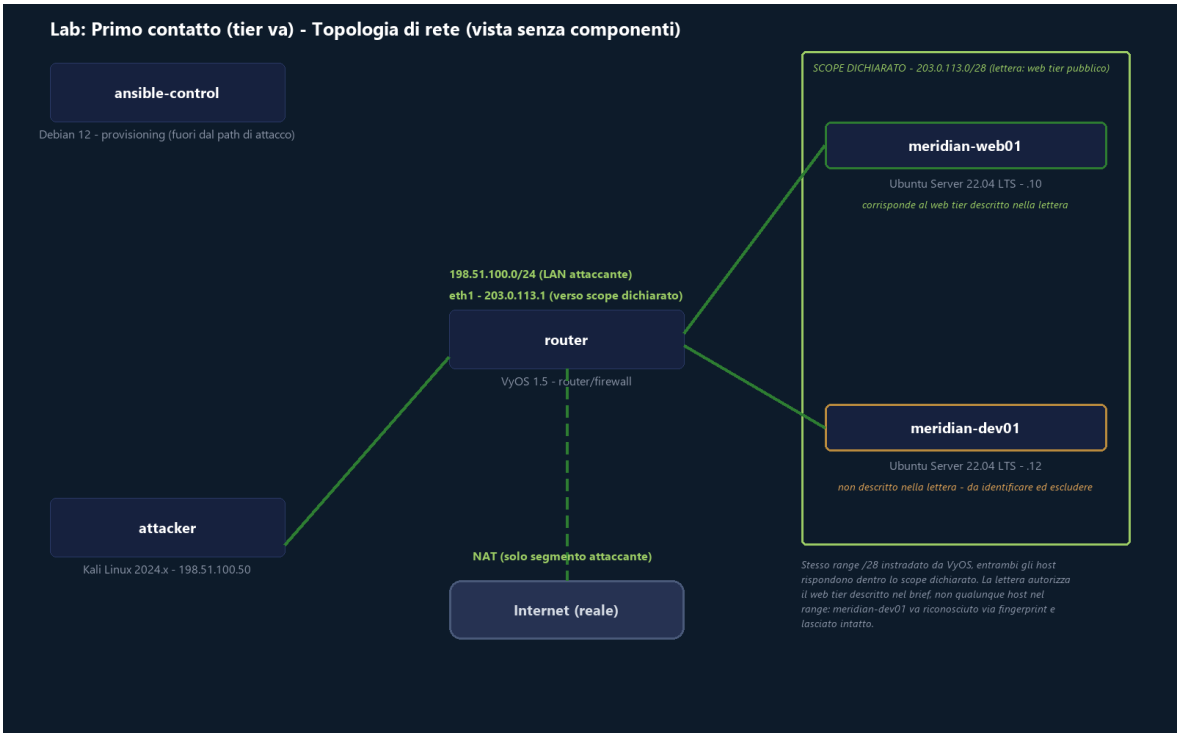
Screenshot reale della pagina di briefing così come appare oggi in piattaforma (versione HTB-restyled). La pagina è un mock-up concettuale: non c'è un ambiente live dietro. Come per i lab precedenti, nessun dato tecnico è già pronto da leggere nel testo: ogni finding deve emergere da un comando eseguito davvero sul target (vedi sezione 7).

2. Infrastruttura

Questo lab riusa l'ambiente di "Primo contatto" e "Come da manuale" (stesso `lxr:net-perimeter`): stessi host, stessa rete, stesso scope dichiarato (203.0.113.0/28). Nessuna macchina nuova, nessun nuovo segmento. L'unica differenza riguarda meridian-web01: viene installato `MySQL Server 5.7.17` (stesso meccanismo `ConfigureLegacyAptSource` + `apt-mark hold` già usato per OpenSSH/Apache), in ascolto su tutte le interfacce con l'account `root` privo di password — un errore di hardening reale, mai corretto dopo l'installazione iniziale, non costruito ad hoc. Il riuso è solo infrastrutturale: non serve aver completato i lab precedenti, questo lab verifica da sé scope e target (sezione 7).



Stessa topologia di Primo contatto, rete e host identici — diagramma sorgente editabile in `risk-language-topology.drawio` (in questa stessa cartella): una copia di `docs/labs/first-contact/first-contact-topology.drawio` con le differenze evidenziate in rosso sulla card di meridian-web01, sullo stesso schema Install → Configure già usato per Apache/SSH — `ConfigureLegacyAptSource` (ora scarica anche MySQL) e la nuova coppia `InstallMySQLServer` / `ConfigureMySQLServer`.



Vista equivalente senza componenti, stesso file sorgente (`first-contact-topology-network-only.drawio`).

3. Perché queste scelte

Storytelling

• **Episodio a sé**: la narrativa non fa alcun riferimento ai lab precedenti — nessun "da quando hai...", nessun collegamento alla trama di Primo contatto o Come da manuale. Solo l'infrastruttura tecnica è condivisa (sezione 2); la storia che il giocatore legge è autonoma.

• **La prima skill di comunicazione della serie (S7)**: i lab precedenti chiedevano di trovare e classificare finding; questo chiede, per la prima volta, di decidere cosa comunicare per primo a chi non è tecnico — non solo di trovarlo.

• **L'analisi di exploitability nelle note della flag 2** (non valutata) collega la CVE a un danno di business concreto — "un attaccante potrebbe interrompere il checkout durante le ore di punta" — senza mai eseguire davvero l'attacco: resta tier va.

• **Nessuna exploitation**: lo script di controllo (`mysql-empty-password`) si ferma a confermare che l'account non ha password — mai un login reale nel database.

Infrastrutturali

• **Riuso totale dell'infrastruttura esistente**: zero macchine nuove, zero segmenti nuovi — solo un servizio in più su un host già provisionato.

• **Account root senza password**: errore di hardening comune e realistico (mai cambiato dal default dopo l'installazione) — stessa narrativa di fondo di OpenSSH/Apache, letta su un servizio diverso.

• **MySQL Server 5.7.17**: è il limite superiore esatto del range colpito da CVE-2017-3599, verificata direttamente sull'API NVD prima di sceglierla.

4. Obiettivi

#	Domanda (flag)	Risposta
1	Scansionando tutte le porte di meridian-web01 trovi un nuovo servizio in ascolto sulla 3306. Quale versione esatta di MySQL identifica il banner?	FLAG{5.7.17}
2	Quale CVE specifica affligge MySQL 5.7.17, permettendo una negazione di servizio pre-autenticazione tramite un pacchetto di autenticazione malformato? Nelle note, annota anche come un attaccante potrebbe sfruttarla per causare danno a Meridian.	FLAG{CVE-2017-3599}
3	Uno script di controllo (mysql-empty-password) rivela un account senza password. Quale?	FLAG{ROOT}
4	Hai due finding aperti su questo servizio: la CVE DoS (disponibilità) e l'account root senza password (accesso completo ai dati ordini). Quale dei due apriresti per primo nell'executive summary al CEO?	FLAG{EMPTY-ROOT-PASSWORD}

Mappatura ECSF: Task T1 "Identify, analyse and assess technical and organisational cybersecurity vulnerabilities" · Skill S7 "Communicate, present and report to relevant stakeholders", S9 "Conduct technical analysis and reporting" · Knowledge K10 "Computer systems vulnerabilities", K11 "Cybersecurity recommendations and best practices".

Perché questi obiettivi

• **Flag 1 (discovery)**: una scansione completa delle porte — non solo quelle già note da Primo contatto — serve a trovare davvero il servizio nuovo, non a ricordarselo.

• **Flag 2 (CVE + exploitability)**: identificare la CVE è lavoro già visto; la novità è nelle note non valutate, dove lo studente deve ragionare su un impatto di business concreto, non solo tecnico.

• **Flag 3 (hardening)**: uno script di controllo passivo, mai un login reale — coerente col tier va.

• **Flag 4 (priorità, il cuore S7)**: costringe a scegliere tra due finding legittimi e a giustificare la scelta in termini di impatto sul business, non di punteggio CVSS — l'account senza password vale più della CVE perché porta ad accesso completo ai dati ordini, non solo a un'interruzione di servizio.

• Nessuna flag richiede exploitation reale: la conferma dell'esposizione basta, coerente col tier va.

5. Tool, OS e configurazioni

Componente	OS / Tecnologia	Install	Configure
meridian-web01 (target, in scope)	Ubuntu Server 22.04 LTS	MySQL Server 5.7.17	ConfigureLegacyAptSource (+ MySQL), ConfigureMySQLServer
attacker	Kali Linux 2024.x	nessun tool nuovo (nmap già presente)	—

Perché proprio questi tool/OS/configurazioni

• **MySQL Server 5.7.17**: scaricato dagli archivi storici come OpenSSH/Apache, bloccato con `apt-mark hold` così che un aggiornamento successivo del sistema non lo sovrascriva.

• **ConfigureMySQLServer**: imposta il bind su tutte le interfacce e lascia l'account root senza password — configurazione di default mai rivista, non un artefatto costruito apposta per far quadrare il lab.

• **Nessun tool nuovo sull'attacker**: nmap (già installato in Primo contatto) include di serie lo script `mysql-empty-password` usato per la flag 3.

6. Playbook section

Da completare. Qui andranno elencati i playbook Ansible effettivi (uno per componente o un playbook unico con ruoli separati), con il percorso del repository e la mappatura ruolo → task Ansible.

7. Lab solution

1. Verifica dello scope

Stesso cliente e stesso blocco autorizzato (203.0.113.0/28) dei lab precedenti — ma la verifica qui sotto è autosufficiente: non serve averli fatti per completare questo.

```
nmap -sV -p- 203.0.113.10
```

Risultato: oltre alle porte 22 e 80 già note, compare una nuova porta 3306 aperta. Il target resta `meridian-web01, 203.0.113.10`.

2. Flag 1 — identificazione del servizio

Il banner restituito dalla scansione precedente identifica `3306/tcp open mysql MySQL 5.7.17` → **FLAG{5.7.17}**.

3. Flag 2 — identificazione CVE ed exploitability

```
searchsploit mysql 5.7.17
```

Emerge CVE-2017-3599: integer overflow nel sottocomponente Pluggable Auth, sfruttabile da remoto senza autenticazione tramite un pacchetto di autenticazione malformato, con impatto di negazione di servizio (CVSS v3.0 7.5, High) → **FLAG{CVE-2017-3599}**. Nelle note (non valutate): un attaccante potrebbe inviare ripetuti pacchetti malformati per mandare in hang/crash il servizio MySQL, interrompendo il processing degli ordini proprio nelle ore di punta — danno di disponibilità, non di dati.

4. Flag 3 — audit hardening credenziali

```
nmap --script mysql-empty-password -p 3306 203.0.113.10
```

Lo script conferma che l'account `root` accetta l'accesso senza password, senza mai eseguire un login reale → **FLAG{ROOT}**.

5. Flag 4 — priorità per l'executive summary

Due finding legittimi sullo stesso servizio: la CVE DoS (solo disponibilità, il servizio torna su dopo il crash) e l'account root senza password (chiunque può leggere o modificare l'intero database ordini, in ogni momento, senza lasciare traccia di un attacco). Per un retailer il danno di un accesso completo e silenzioso ai dati clienti supera quello di un'interruzione temporanea → **FLAG{EMPTY-ROOT-PASSWORD}**.

6. Report finale

Tabella finding → impatto → raccomandazione, pronta per un lettore non tecnico: l'account root senza password è la priorità assoluta (accesso completo e silenzioso ai dati ordini, va corretto subito con una password e un utente applicativo dedicato); la CVE DoS resta una priorità secondaria di patching (aggiornamento a una versione MySQL corrente, disponibilità del servizio durante i picchi di traffico).